AWS Solutions Architecture Notes

Your Name

Date:

Contents

1 Course Introduction **5**

2 Identity & Federation **7**
2.1 IAM - What should you know by now . . . 7
2.1.1 IAM Policies Deep Dive . . . 7
2.1.2 IAM AWS Managed Policies - Administrator Access example . . . 7
2.1.3 IAM Policies Conditions . . . 8
2.1.4 IAM Policies Variables and Tags . . . 8
2.1.5 IAM Roles vs Resource Based Policies . . . 8
2.1.6 IAM Permissions Boundaries . . . 8
2.1.7 Use cases . . . 8
2.1.8 IAM Access Analyser . . . 8
2.1.9 IAM Access Analyser . . . 8
2.2 STS . . . 8
2.2.1 Using STS to Assume a Role . . . 8
2.2.2 Assuming a Role with STS . . . 9
2.2.3 Providing Access to an IAM User in Yours or Another AWS Account That You Own . . . 9
2.2.4 Providing Access to AWS Accounts Owned by Third Parties . . . 9
2.2.5 Identity Federation in AWS . . . 10
2.2.6 AWS Directory Services (AD)? . . . 11
2.2.7 AWS Orgnisations . . . 12
2.2.8 AWS IAM Identity Center . . . 14
2.3 AWS Resource Access Manager (RAM) . . . 15
2.4 Summary of Identity and Federation . . . 16

3 Security **17**
3.1 CloudTrail . . . 17
3.2 CloudTrail - EventBridge Integration . . . 17
3.3 CloudTrail - SA Pro . . . 17
3.4 KMS . . . 18
3.5 Parameter Store . . . 19
3.6 Secrets Mangager . . . 19
3.7 RDS Security . . . 19
3.8 SSL Encryption, SNI, MITM . . . 20
3.9 AWS Certificate Manager - ACM . . . 20
3.10 CloudHSM . . . 21

3.11 Solution Architecture - SSL on ELB . . . 21
3.12 S3 Security . . . 21
3.13 S3 Access Points . . . 22
3.14 S3 Multi-Region Access Points . . . 22
3.15 S3 Multi-Region Access Points - Hands On . . . 22
3.16 S3 Object Lambda . . . 22
3.17 DDoS and AWS Shield . . . 23
3.18 AWS WAF - Web Application Firewall . . . 23
3.19 AWS Firewall Manager . . . 24
3.20 Blocking an IP Address . . . 24
3.21 Amazon Inspector . . . 24
3.22 AWS Config . . . 25
3.23 AWS Managed Logs . . . 25
3.24 Amazon GuardDuty . . . 25
3.25 IAM Advanced Policies . . . 26
3.26 EC2 Instance Connect . . . 26
3.27 AWS Security Hub . . . 26
3.28 Amazon Detective . . . 26

4 Compute & Load Balancing 27
4.1 Solution Architecture on AWS . . . 28
4.2 EC2 . . . 28
4.3 High Performance Computing (HPC) . . . 28
4.4 Auto Scaling . . . 28
4.5 Auto Scaling Update Strategies . . . 28
4.6 Spot Instances and Spot Fleet . . . 28
4.7 Amazon ECS - Elastic Container Service . . . 28
4.8 Amazon ECS - Elastic Container Registry . . . 28
4.9 Amazon EKS - Elastic Kubernetes Service . . . 28
4.10 AWS App Runner . . . 28
4.11 ECS Anywhere and EKS Anywhere . . . 28
4.12 AWS Lambda - Part 1 . . . 28
4.13 AWS Lambda - Part 2 . . . 28
4.14 Elastic Load Balancers - Part 1 . . . 28
4.15 Elastic Load Balancers - Part 2 . . . 28
4.16 API Gateway . . . 28
4.17 API Gateway - Part 2 . . . 28
4.18 AWS AppSync . . . 28
4.19 Route 53 - Part 1 . . . 28
4.20 Route 53 - Part 2 . . . 28
4.21 Route 53 - Resolvers and Hybrid DNS . . . 28
4.22 AWS Global Accelerator . . . 28
4.23 Comparison of Solution Architecture . . . 28
4.24 AWS Outposts . . . 28
4.25 AWS WaveLength . . . 28
4.26 AWS Local Zoness . . . 28

5 Storage **29**
5.1 EBS and Local Instance Store . . . 29
5.2 Amazon EFS . . . 29
5.3 Amazon S3 . . . 29
5.4 Amazon S3 - Storage Class Analysis . . . 29
5.5 Amazon S3 - Storage Lens . . . 29
5.6 S3 Solution Architecture . . . 29
5.7 Amazon FSx . . . 29
5.8 Amazon FSx - Solution Architecture . . . 29
5.9 AWS DataSync . . . 29
5.10 AWS DataSync - Solution Architecture . . . 29
5.11 AWS Data Exchange . . . 29
5.12 AWS Transfer Family . . . 29
5.13 AWS Storage Services Price Comparison . . . 29

6 Caching **31**
6.1 Cloudfront - Part 1 . . . 31
6.1.1 CloudFront - Origins . . . 31
6.1.2 CloudFront - S3 as an Origin . . . 31
6.1.3 CloudFront vs S3 Cross Region Replication . . . 31
6.1.4 CloudFront - ALB or EC2 as an origin Using VPC Origins . . . 31
6.1.5 CloudFront - EC2 or ALB as an origin . . . 32
6.1.6 CloudFront - Restrict Access to Application Load Balancers and Custom Origins . . . 32
6.1.7 CloudFront - Origin Groups . . . 32
6.2 Cloudfront - Part 2 . . . 32
6.2.1 CloudFront Geo Restrictions . . . 32
6.2.2 CloudFront - Pricing . . . 32
6.2.3 CloudFront - Price Classes . . . 32
6.2.4 CloudFront Signed URL Diagram . . . 32
6.2.5 CloudFront Signed URL vs S3 Pre-Signed URL . . . 32
6.2.6 CloudFront - Custom Error Pages . . . 33
6.3 Lambda at Edge and CloudFront Functions . . . 33
6.3.1 CloudFront - Customisation at the edge . . . 33
6.3.2 CloudFront Functions and Lamabda at Edge . . . 33
6.3.3 CloudFront - CloudFront Functions . . . 33
6.3.4 CloudFront - Lambda at Edge . . . 33
6.3.5 CloudFront Functions with Lambda at Edge . . . 33
6.3.6 Using Lambda at Edge only . . . 33
6.3.7 CloudFront Funtions vs. Lamda at Edge . . . 34
6.3.8 CloudFront Funcitons vs Lambda at Edge Use Cases . . . 34
6.3.9 CloudFront Functions vs. Lambda at Edge - Authentication and Authorisation 34
6.3.10 Lambda@Edge: Loading content based on User-Agent . . . 34
6.3.11 Lambda at Edge - Global Application . . . 34
6.4 Lambda at Edge Reduce Latency . . . 34
6.4.1 Lambda at Edge - Route to different origin . . . 34
6.5 Amazon ElastiCache . . . 34
6.5.1 Amazon ElasticCache Overview . . . 34

6.5.2 ElastiCache Solution Architecture - DB Cache . . . 34
6.5.3 ElastiCache Solution Architecture - User Session Store . . . 34
6.5.4 ElastiCache - Redis vs Memcached . . . 35
6.6 Handling Extreme Rates . . . 35

7 Databases 37
7.1 DyanamoDB . . . 37
7.2 Amazon OpóenSearch . . . 37
7.3 RDS . . . 37
7.4 Aurora - Part 1 . . . 37
7.5 Aurora - Part 2 . . . 37

8 Service Communication 39
8.1 Step Functions . . . 39
8.2 SQS . . . 39
8.3 Amazon MQ . . . 39
8.4 Amazon SNS . . . 39
8.5 Amazon SNS - SQS Fan Out Pattern . . . 39
8.6 Amazon SNS - Message Delivery Retries . . . 39

9 Data Engineering 41
9.1 Amazon Kinesis Data Streams . . . 41
9.2 Amazon Data Firehose . . . 41
9.3 Amazon Managed Service for Apache Flink . . . 41
9.4 Streaming Architectures . . . 41
9.5 Amazon MSK . . . 41
9.6 AWS Batch . . . 41
9.7 Amazon EMR . . . 41
9.8 Running Jobs on AWS . . . 41
9.9 AWS Glue . . . 41
9.10 Redshift . . . 41
9.11 Amazon DocumentDB . . . 41
9.12 Amazon Timestream . . . 41
9.13 Amazon Athena . . . 41
9.14 Amazon QuickSight . . . 41
9.15 Big Data Architecture . . . 41

10 Monitoring 43
10.1 CloudWatch . . . 43
10.2 CloudWatch Logs . . . 43
10.3 Amazon EventBridge . . . 43
10.4 X-Ray . . . 43
10.5 AWS Personal Health Dashboard . . . 43

11 Deployment and Instance Management 45
11.1 Elastic Beanstalk . . . 45
11.2 CodeDeploy . . . 45
11.3 CloudFormation . . . 45

11.4 Service Catalog . . . 45
11.5 SAM - Serverless Application Model . . . 45
11.6 AWS CDK - Cloud Development Kit . . . 45
11.7 AWS Systems Manger - SSM . . . 45
11.8 AWS Cloud Map . . . 45

12 Cost Control **47**
12.1 Cost Allocation Tags . . . 47
12.2 AWS Tag Editor . . . 47
12.3 Trusted Advisor . . . 47
12.4 AWS Service Quotas . . . 48
12.5 EC2 Launch Types and Savings Plans . . . 48
12.5.1 AWS Savings Plan . . . 48
12.6 S3 Cost Savings . . . 49
12.6.1 S3 Storage Classes . . . 49
12.6.2 S3 - Other Cost Savings . . . 49
12.7 S3 Storage Classes - Reminder . . . 49
12.7.1 S3 Storage Classes . . . 49
12.7.2 S3 Durability and Availalbility . . . 49
12.7.3 S3 Intelligent Tiering . . . 50
12.8 AWS Budgets and Cost Explorer . . . 50
12.8.1 AWS Budgets . . . 50
12.8.2 Budget Actions . . . 50
12.8.3 Centralised Budget Management . . . 50
12.8.4 DeCentralised Budget Management . . . 50
12.8.5 Cost Explorer . . . 50
12.9 AWS Compute Optimiser . . . 51
12.9.1 Computer Optimiser - CloudWatch Agent . . . 51
12.10 EC2 Reserved Instance . . . 51

13 Migration **53**
13.1 Cloud Migration Strategies - The 7Rs . . . 53
13.2 Storage Gateway . . . 53
13.3 Storage Gateway - Advanved Concepts . . . 53
13.4 Snow Family . . . 53
13.5 Snow Family - Improving Performance . . . 53
13.6 AWS DMS - Database Migration Services . . . 53
13.7 AWS CART - Cloud Adoption Readiness Tool . . . 53
13.8 Disaster Recovery . . . 53
13.9 AWS FIS - Fault Injection Simulator . . . 53
13.10 VM Migrations Serrvices . . . 53
13.11 AWS Migration Evaluator . . . 53
13.12 AWS Backup . . . 53

14 VPC **55**
14.1 VPC - Basiscs . . . 55
14.2 VPC - Peering . . . 55
14.3 Transit Gateway . . . 55

14.4 VPC Endpoints . . . 55
14.5 VPC Enpoint Policies . . . 55
14.6 PrivateLink . . . 55
14.7 AWS S2S VPN . . . 55
14.8 AWS Client VPN . . . 55
14.9 Direct Connect . . . 55
14.10 On-Premise Redundant Connections . . . 55
14.11 VPC Flow Logs . . . 55
14.12 AWS Network Firewall . . . 55

15 Machine Learning **57**
15.1 Rekognition Overview . . . 57
15.1.1 Amazon Rekognition - Content Moderation . . . 57
15.2 Transcribe Overview . . . 57
15.3 Polly Overview . . . 57
15.3.1 Amazon Polly - Lexicon & SSML . . . 57
15.4 Translate Overview . . . 58
15.5 Lex + Connect Overview . . . 58
15.6 Comprehend Overview . . . 58
15.7 Comprehend Medical Overview . . . 58
15.8 SageMaker Overview . . . 58
15.9 Kendra Overview . . . 58
15.10 Personalise Overview . . . 59
15.11 Textract Overview . . . 59
15.12 Machine Learning Summary . . . 59

16 Other Services **61**
16.1 Other Services . . . 61
16.2 IMPORTANT: CodeCommit Discontinuation . . . 61
16.3 CI/CD . . . 61
16.4 Amazon CodeGuru . . . 61
16.5 Alexa for Business, Lex and Connect . . . 61
16.6 Kinesis Video Streams . . . 61
16.7 AWS WorkSpaces . . . 61
16.8 Amazon AppStream 2.0 . . . 61
16.9 AWS Device Farm . . . 61
16.10 Amazon Macie . . . 61
16.11 Amazon SES . . . 61
16.12 Amazon Pinpoint . . . 61
16.13 EC2 Image Builder . . . 61
16.14 Other Services Summary . . . 61

17 Exam Preparation **63**

Chapter 1

Course Introduction

Pre-Introduction The purpose of these notes are two-fold.

- Prepare for this exam in the future.
- Gain a high level overview of the services offered by one of the main cloud providers.
- Additionally, could be useful for practicing Terraform.

Chapter 2

Identity & Federation

2.1 IAM - What should you know by now

- Users: Long term credentials - Groups - Roles: short-term credentials, uses STS - EC2 Instance Roles: Uses the EC2 metadata service. One role of a time per instance - Service Roles: API Gateways, CodeDeploy etc - Cross Account roles - Policies - AWS Managed - Customer Managed - Inline Policies - Resource Based Policies (S3 Bucket, SQS queues, etc.....)

2.1.1 IAM Policies Deep Dive

- Anatomy of a policy: JSON doc with Effect, Action, Resource, Conditions, Policy Variables - Explicit DENY has precedence over ALLOW - Best practice: use least privilege for maximum security - Access Advisor: See permissions granted and when last accessed - Access Analyser: Analyse resources that are shared with external entity - Navigate Examples at:

2.1.2 IAM AWS Managed Policies - Administrator Access example

Listing 2.1: Sample JSON Data

```
{
"Version": "2012-10-17",
"Statement": [
{
"Effect": "Allow",
"Action": "*",
"Resource": "*"
}
]
}
```

2.1.3 IAM Policies Conditions

2.1.4 IAM Policies Variables and Tags

2.1.5 IAM Roles vs Resource Based Policies

- Attach a policy to a resource (example: S3 bucket policy) versus attaching of a using a role as a proxy - When you assume a role (user, application or service), you give up your original permissions and take the permissions assigned to the role. - When using a resource-based policy, the principal doesn't have to give up any permissions - Example: User in account A needs to scan a DynamoDB table in Account A and dump it in an S3 bucket in Account B

2.1.6 IAM Permissions Boundaries

- IAM permission boundaries are supported for users and roles (not groups) - Advanced feature to use a managed policy to set the maximum permissions an IAM entity can get - Can be used in combinations of AWS organisations SCP

2.1.7 Use cases

- Delegate responsibilities to non administrators within their permission boundaries, for example create create new IAM users
- Allow developers to self-assign policies and managed their own permissions while making sure they can't 'escalate' their privileges (i.e make themselves admin)
- Useful to restrict one specific user (instead of a whole account using Organisations and SCP)

2.1.8 IAM Access Analyser

- Find out which resources are shared externally - S3 Buckets - IAM Roles - KMS Keys - Lambda Functions and Layers - SQS queues - Secrets Manager Secrets - Define Zone ofTrust = AWS Account or AWS Organisation - Access outside of zone trusts =¿ findings

2.1.9 IAM Access Analyser

- IAM Access Analyser Policy Validation - Validates your policy against IAM policy grammar and best practices - General warnings, security warnings errors suggestions - Provides actionable recommendations - IAM Access Analyser Policy Generation - Generates IAM policy based on access activity - CloudTrail logs is reviewed to generate the policy with the fine-grained permissions and the appropriate Actions and Services - Reviews CloudTrail logs for up to 90 days

2.2 STS

2.2.1 Using STS to Assume a Role

- Define an IAM Role within your account or cross-account - Define which principals can access this IAM role - Using AWS STS (Security Token Service) to retrieve credentials and impersonate the IAM role you have access to (AssumeRole API) - Temporary credentials can be valid between 15 to 12 hours.

2.2.2 Assuming a Role with STS

- Provide access for an IAM user in one AWS account that you own to access resources in another account that you own. - Provide access to IAM users in AWS accounts owned by third parties - Provide access for services offered by AWS to AWS resources - Provide access for externally authenticated users (identity federation) - Ability to revoke active sessions and credentials for a role (by adding a policy using a time statement - AWSRevokeOlderSessions)

When you assume a role (user, application or service), you give up your original permissions and take the permissions assigned to the role.

2.2.3 Providing Access to an IAM User in Yours or Another AWS Account That You Own

- You can grant your IAM users permissions to switch to roles within your AWS account or to roles defined in other AWS accounts that you own. - Benefits: - You must explicitly grant your

users permission to assume the role - Your users must actively switch to the role using the AWS management console or assume the role using the AWS CLI or AWS API - You can add multi-factor authentication (MFA) protection to the role so that only users who sign in with an MFA device can assume the role. - Least Privilege + auditing using CloudTrail

2.2.4 Providing Access to AWS Accounts Owned by Third Parties

- Zone of trust = accounts, organisations that you own - Outside Zone ofTrust = 3rd parties - Use IAM Access Analyser to find out which resources are exposed - For granting access to a thrid party: - The third part AWS account ID - An External ID (secret between you and the third party) - To uniquely associate with the role between you and 3rd party - Must be provided when defining the trust and when assuming the role - Must be chosen by the third party - Define permissions in the IAM policy

Session Tags in STS

- Tags that you pass when you assume an IAM Role or federate user in STS - aws:PrincipalTag Condition - Compares the tags attached to the principal making the request with the tag you specified in the policy. - Example: Allow a principal to pass session tags only if the principal making the reqeust has the specified tags.

STS Important APIs

- AssumeRole: access a role within your account or cross-account - AssumeRoleWithSAML: return credentials for users logged with SAML - AssumeRoleWithWebIdentity: return creds for users logged with an IdP - Example providers include Amazon Cognito, Login with Amazon, Facebook, Google or any OpenID Connect-compatible identity provider. - AWS Recommends using Cognito - GetSessionToken: for MFA from a user or AWS account root user - GetFederationToken: obtain temporary creds for a federated user, usually a proxy app that will give the creds for a federated user, usually a proxy app that will give the creds to a distributed app inside a corporate network.

2.2.5 Identity Federation in AWS

- Give users outside of AWS permissions to access AWS resources in your account - You don't need to create IAM Users (user management is outside AWS) - Use cases: - A corporate has its own identity system (e.g Active Directory) - Web / Mobile application that needs access to AWS resources - Identity Federation can have many flavours: - SAML 2.0 - Custom Identity Broker - Web Identity Federation With(out) Amazon Cognito - IAM Identity Centre

SAML 2.0 Federation

- Security Assertion Markup Language 2.0 (SAML 2.0) - Open standard used by many identity providers (e.g ADFS) - Supports integration with Microsoft Active Directory Federations Services (ADFS) - Or any SAML 2.0 - compatible IdPs with AWS - Access the AWS Console, AWS CLI or AWS API using temporary credentials - No need to create IAM Users for each of your employees - Need to setup a trust between AWS IAM and SAML 2.0 Identity Provider (both ways) - Under-the-hood: Uses the STS API AssumeRoleWithSAML - SAML 2.0 Federation is the "old way", IAM Identity Center Federation is the new managed and simpler way

SAML 2.0 Federation - AWS API Access

SAML 2.0 Federation - AWS Console Access

SAML 2.0 Federation - Active Directory DS (ADFS)

Custom Identity Broker Application

- Use only if identity provider is NOT compatible with SAML 2.0 - The identity broker is NOT compatible with SAML 2.0 - The identity broker must determine the appropriate IAM Role - Uses the STS API AssumeRole or GetFederationToken

Web Identity Federation - Without Cognito

- Not recommended by AWS - use cognito instead

Web Identity Federation - With Cognito

- Preferred over for Web Identity Federation - Create IAM Roles using Cognito with the least privilege needed - Build trust between the OIDC IdP and AWS - Cognito benefits: - Supports anonymous users - Supports MFA - Data Synchronisation - Cognito replaces a Token Vending Machine (TVM)

Web Identity Federation - IAM Policy

- After being authenticated with Web Identity Federation, you can identify the user with an IAM policy variable - Example:

2.2.6 AWS Directory Services (AD)?

- Found on any Windows Server with AD Domain Services - Database of objects: User Accounts, Computers, Printers, File Shares, Security Groups - Centralised security management, create account, assign permissions - Objects are organised in trees - A group of trees

What is ADFS (AS Federation Services)?

- ADFS provides Single Sign-On across applications - SAML across 3rd party: AWS Console, Dropbox, Officer365, etc.....

AWS Directory Services

- AWS Managed Microsoft AD - Create your own AD in AWS, manage users, locally supports MFA - Establish ”trust” connection with your own on premises - AD Connector - Directory Gateway (proxy) to redirect to on-premises AD, supports MFA - Users are managed on the on-premise AD - Simple AD - AD-compatible managed directory on AWS - Cannot be joined with on-premise AD

AWS Directory Services and AWS Managed Microsoft AD

- Managed Service: Microsoft AD in your AWS VPC - EC2 Windows Instances: - EC2 Windows instances can join the domain and run traditional AD applications (sharepoint, etc) - Seamlessly Domain Join Amazon EC2 Instances from Multiple Accounts and VPCs - Integrations - RDS for SQL Server, AWS Workspaces, Quicksight..... - AWS SSO to provide access to third party applications - Standalone repository in AWS or jointed to on-premises AD - Multi AZ deployment of AD in 2 AZ, of DC (Domain Controllers) can be increased for scaling - Automated backups - Automated Multi-Region replication of your directory

AWS Microsoft Managed AD - Integrations

Connect to on-premise AD

- Ability to connect your on-premise Active Directory to AWS Managed Microsoft AD - Must establish a Direct Connection (DX) or VPN connection - Can setup three kinds of forest trust - One-way trust: AWS -¿ On-Premise - One-way trust: On-Premise -¿ AWS - Two-way forest: trust - AWS -¿ On-Premise - Forest trust is different than synchronisation (replication is not supported)

Solution Achitecture: Active Directory Replication

- You may want to create a replica of your AD on EC2 in the cloud to minimise latency of in case DX or VPN goes down - Establish trust between the AWS Manged Microsoft AD and EC2

AWS Directory Services AD Connector

- AD Connector is a directory gateway to redirect director requests to your on premises Microsoft Active Directory - No caching capability - Managed users solely on-premise, no possibility of setting up a trust - VPN or Direct Connect - Doesn't work with SQL Server, doesn't do seamless joining, can't share director.

AWS Directory Services Simple AD

- Simple AD is an inexpensive Active Directory-compatible service with the common directory features - Supports joining EC2 instances, manage users and groups - Does not support MFA, RDS SQL server, AWS SSO - Small: 500 users, large: 5000 users - Powered by Samba 4, compatible with Microsoft AD - lower cost, low scale, basic AD compatible or LDAP compatibility - No trust relationship

2.2.7 AWS Orgnisations

AWS Organisations - OrgnizationAccountAccessRole

- IAM role which grants full administrator permissions in the Member account to the Management account - Used to perform admin tasks in the Member accounts (e.g - creating IAM users) - Could be assumed by IAM users in the Management account - Automatically added to all new Member account created with AWS organisations - Must be created manually if you invite an existing Member account

Multi Account Strategies

- Create accounts per department, per cost centre, per dev / test / prod, based on regulatory restrictions (using SCP), for better resource isolation (ex:VPC), to have separate per-account service limits isolated account for logging. - Multi Account vs. On Account MultiVPC - Use tagging standards for billing purposes - Enable CloudTrail on all accounts, send logs to central S3 account - Send CloudWatch logs to central logging account - Strategy to create an account for security

Orgnisational Units (OU) - Examples

AWS Organisation - Feature Modes

- Consolidated billing features: - Consolidated Billing across all accounts - single payment method - Pricing benefits from aggregated usage (volume discount for EC2, S3.....)

All Features (Default)

- Includes consolidated billing features, SCP - Invited accounts must approve enabling all features - Ability to apply an SCP to prevent member accounts from leaving the org - Can't switch back to Consolidated Billing Features only

AWS Organisations - Reserved Instances

- For billing purposes, the consolidated billing features of AWS organisations treats all the accounts in the organisation as one account. - The means that all accounts in the organisation can receive the hourly cost benefit of Reserved Instances that are purchased by any other account. - The payer account (Management account) of an organisation can turn off Reserved Instance (RI) discount and Saving Plans discount sharing for any accounts in that organisation, including the payer account. - This means that RIs and Saving Plans discounts aren't shared between any accounts that have sharing turned off. - To share an RI or Savings Plans discount with an account, both accounts must have sharing turned on.

AWS Organisation - Moving Accounts

- Remove the member account from the AWS organisation - Send an invite to the member account from the AWS organisation - Accept the invite to the new Organisation from the member account.

Service Control Policies (SCP)

- Define allowlist or blocklist IAM actions - Applied at the OU or Account level - Does not apply to the Management Account - SCP is applied to all the Users and Roles in the account, including Root user - The SCP does not affect Service-linked roles - Service-linked roles enable other AWS services to integrate with AWS organisations and can't be restricted by SCP's - SCP must have an explicit Allow from the root of each OU in the direct path to the target account (does not allow anything by default) - Use cases: - Restrict access to certain services (for example: can't use EMR) - Enforce PCI compliance by explicitly disabling services.

SCP Hierarchy

- Management Account - Can do anything (no SCP apply) - Account A - Can do anything - EXCEPT S3 (explicit Deny from Sandbox OU) - EXCEPT EC2 (explicit deny) - Account B and C - Can do anything - EXCEPT S3 (explicit Deny from Sandbox OU) - Account D - Can access EC2 - Prod OU and Account E and F

SCP Examples - Blocklist and Allowlist strategies

IAM Policy Evaluation Logic

Restricting Tags with IAM policies

- You can restrict specific tags on AWS resources - Using the aws:TagKeys Condition Key - Validate the Tag Keys attached to a resource against the Tag Keys in the IAM Policy - Example: Allow IAM users to create EBS Volumes only if it has the ”Env” and ”CostCenter” Tags - Use either ForAllValues (must have all keys) or ForAnyValue (must have any of these keys at a minimum)

Using SCP to restrict creating resources without appropriate tags

- Prevent IAM Users/Roles in the affected member accounts from creating resources if they don’t have a specific Tag

AWS Organisations - Tag Policies

- Helps you standardise tags across resources in an AWS organisation - Ensure consistent tags, audit tagged resources, maintain proper resources categorisation - You define Tag keys and their allowed values - Helps with AWS Cost Allocation Tags and Attribute-based Access Control - Prevent any non-compliant tagging operations on specified services and resources - Generate a report that lists all tagged/ non compliant resources - Use Amazon EventBridge to monitor non-compliant tags

AWS Organisation - AI Service Opt-out Policies

- Certain AWS AI services may use your content for continuous improvement of Amazon AI/ML services - Example: Amazon Lex, Amazon Comprehend, Amazon Polly..... - You can opt-out of having your content stored or used by AWS AI services - Create an Opt-out Policy that enforces this setting across all Member accounts and AWS Regions - You can opt-out all AI services or selected services - Can be attached to Organisation Root, specific OU or individual Member account

AWS Organisations - Backup policies

- AWS Backup enables you to create Backup Plans that define how to backup your AWS resources - JSON Documents that define backup plans across an AWS Organisation - Gives you granular control over backup up your resources (e.g backup frequency, time window, backup region,.....) - Can be attached to Organisation Root, specific OU or individual Member account - Immutable backup plans appear in Member accounts (view only)

Using SCP to Deny a Region aws:ReqeustRegion

2.2.8 AWS IAM Identity Center

AWS IAM Identity Center -successor to AWS Single Sign-On-

- One login (single sign-on) for all your - AWS accounts in AWS organisations - Business cloud applications (e.g, Salesforce, Box, Microsoft 365) - SAML2.0 enabled applications - EC2 windows instances

- Identity Providers - Built-in identity store in IAM identity center - 3rd party Active Directory (AD), OneLogin, Okta

- AWS IAM Identity Center - Login Flow

AWS IAM Identity Center

AWS IAM Identity Center - Fine-grained Permissions and Assignments

- Multi-Account Permissions - Manage access across AWS accounts in your AWS Organisation - Permission Sets - a collection of one or more IAM policies assigned to users and groups to define AWS access - Application Assignments - SSO access to many SAML 2.0 business applications (Salesforce, Box, Microsoft 365) - Provide required URLs, certificates and metadata - Attribute-Based Access Control (ABAC) - Fine-grained permissions based on users' attributes stored in IAM identity center identity store - Example: Cost center, title, locale - Use case: Define permission once, then modify AWS access by changing the attributes

AWS Control Tower

- Easy way to setup and govern a secure and compliant multi-account AWS environment based on best practices - Benefits: - Automate the set up of your environment in a few clicks - Automate ongoing policy management using guardrails - Detect policy violations and remediate them - Monitor compliance through an interactive dashboard - AWS ControlTower runs on top AWS Organisations: - It automatically sets up AWS Organisations to organise accounts and implement SCPs (Service Control Policies)

AWS Controller Tower - Account Factory

- Automates account provisioning and deployments - Enables you to create pre-approved baselines and configuration options for AWS accounts in your organisation (e.g VPC default configuration, subnets, region, ...) - Uses AWS service catalog to provision new AWS accounts

AWS Control Tower - Detect and Remediate Policy Violations

- Guardrail - Provide ongoing governance for your Control Tower environment (AWS Accounts) - Preventive - using SCPs (e.g Disallow Creation of Access Keys for the Root User) - Detective - users AWS Config (e.g Detect Whether MFA for the Root User is Enabled) - Example: identify non-compliant resources (e.g, untagged resources)

AWS Control Tower - Guardrails Levels

- Mandatory - Automatically enabled and enforced by AWS control tower - Example: Disallow public Read access to the Log Archive account - Strongly Recommended - Based on AWS best practices (optional) - Example: Enable encryption for EBS volumes attached to EC2 instances - Elective - Commonly used by enterprises (optional) - Examples: Disallow delete actions without MFA in S3 buckets

2.3 AWS Resource Access Manager (RAM)

- Share AWS resources that you own with other AWS accounts - Share with any account or within your Organisation - Avoid resource duplication! - VPC Subnets - Allow to have all the resources launched in the same subnets - Must be from the same AWS organisations - Cannot share security groups and defaultVPC - Participants can manage their own resources in there - Participants can't view, modify, delete resources that belong to other participants or the owner - AWS Transit Gateway - Route 53 (Resolver Rules, DNS Firewall Rule Groups) - License Manager Configurations

AWS Resource Access Manager (RAM)

- Aurora DB Clusters - ACM Private Cerficiate Authority - CodeBuild Project - EC2 (Dedicated Hosts, Capacity Reservation) - AWS Glue (Catalog, Database, Table) - AWS Network Firewall Policies - AWS Resources groups - Systems Manager Incident Manager (Contacts, Response Plans) - AWS Outposts (Outpost, Site)

Resource Access Manager - VPC example

- Each account..... - Is responsible for it own resources - Cannot view modify or delete other resources in other accounts - Network is shared so..... - Anything deployed in the VPC can talk to other resources in the VPC - Applications are accessed easily across accounts, using a private IP - Security groups from other accounts can be referenced for maximum security - Use cases - Applications within the same trust boundaries - Applications with a high degree of interconnectivity

Resource Access Manager Managed Prefix List

- A set of one or more CIDR blocks - Makes it easier to configure and maintain Security Groups and Route Tables - Customer-Managed Prefix List - Set of CIDRs that you define and manage by you - Can be shared with other AWS accounts or AWS Organisation - Modify to update many security groups at once - AWS-Managed Prefix List - Set of CIDRs for AWS services - You can't create, modify, share or delete them.

Resource Access Manger Route 53 Outbound Resolver

- Helps you scale forwarding rules to your DNS in case you have multiple accounts and VPC

2.4 Summary of Identity and Federation

- Users and Accounts all in AWS
- AWS Organisations
- AWS Control Tower to setup secure and compliant multi-account AWS environment (best practices)
- Federation with SAML
- Federation without SAML with a custom IdP (GetFederationToken)
- IAM Identity Center to connect to multiple AWS Accounts (Organisation) and SAML apps
- Web Identity Federation (not recommended)
- Cognito for most web and mobile applications (has anonymous mode, MFA)
- AWS Directory Service:
  - Managed Microsoft AD - standalone or setup trust AD with on-premises, has MFA, seamless joins, RDS integration
  - AD Connector - proxy requests to on-premises
  - Simple AD - standalone and cheap AD-compatible with no MFA, no advanced capabilities
- AWS RAM to share resource (example VPC subnets)